Informe Técnico de Auditoría de Seguridad

Actividad A08 — Hacking Ético

Cliente: **INSECUR S.A.** — Laboratorio: TryHackMe

Seguridad Aplicada a Sistemas de Información
Licenciatura en Sistemas de Información — Facultad de Informática y Diseño
Docente: Ing. Rodrigo Atilio Elgueta

Índice

1. Datos Generales del Trabajo Práctico 2
2. Alcance y Metodología 2
3. Resumen Ejecutivo de Hallazgos 2
4. Detalle de Hallazgos 2
5. Protocolo de Contingencia 3
6. Declaración Ética 4

1. Datos Generales del Trabajo Práctico

Campo	Valor
Cliente	INSECUR S.A.
Contratista (Estudiante)	Ignacio De Paz
DNI	46325541
Username TryHackMe	ignaciodepaz
Email institucional	ignaciodepaz0501@gmail.com
Sala de Elección (Nivel 2)	Vulnversity
Rama en GitHub	`depaz-ignacio`
Fecha de Inicio	27/09/2026
Fecha de Cierre	30/09/2026

2. Alcance y Metodología

La evaluación comprende los entornos de laboratorio asignados en TryHackMe para la sala *Basic Pentesting* y la sala de elección *Vulnversity*, limitándose a las direcciones IP asignadas mediante la interfaz VPN.

Se aplica el estándar PTES (Penetration Testing Execution Standard) integrado con los lineamientos de NIST SP 800-115 y OWASP WSTG para la fase web.

3. Resumen Ejecutivo de Hallazgos

Severidad	Cantidad	ID de Hallazgos
Crítico	1	H-04 (Exposición de Clave Privada RSA)
Alto	1	H-03 (Credenciales Débiles en SSH)
Medio	1	H-02 (Directorio Web Expuesto)
Bajo	1	H-01 (Exposición de Puertos y Servicios)
Total	4	

4. Detalle de Hallazgos

Campo	Valor
ID Hallazgo	H-01
Fase	Escaneo / Enumeración

Descripción	Servicios expuestos en puertos TCP (22, 80, 139, 445, 8009, 8080).
CVSS Estimado	Medio
Evidencia	Captura `escaneo_H-01.png`
Salvaguarda	Filtrado de puertos mediante firewall (UFW/iptables).
ID Hallazgo	H-02
Fase	Escaneo / Enumeración Web
Descripción	Directorio sensible oculto (`/development`) hallado mediante Gobuster.
CVSS Estimado	Medio
Evidencia	Captura `escaneo_H-02.png`
Salvaguarda	Restricción de acceso y eliminación de directorios de prueba.
ID Hallazgo	H-03
Fase	Explotación
Descripción	Contraseña débil en la cuenta del usuario `jan`.
CVSS Estimado	Alto
Evidencia	Capturas `hydra_jan.png` y `ssh_jan_access.png`
Salvaguarda	Autenticación exclusiva por claves y políticas de complejidad.
ID Hallazgo	H-04
Fase	Post-Explotación / Movimiento Lateral
Descripción	Clave privada RSA de `kay` almacenada con permisos inseguros.
CVSS Estimado	Crítico
Evidencia	Capturas `john_kay.png` y `ssh_kay_flag.png`
Salvaguarda	Permisos estrictos (`chmod 600`) y remoción de claves expuestas.

5. Protocolo de Contingencia

Ante una eventual interrupción o bloqueo del servicio SSH por sobrecarga de peticiones:

1. **Contención:** Detección mediante monitoreo y bloqueo de IP origen.
2. **Recuperación:** Reinicio del servicio `sshd` e inspección de logs.
3. **Métricas:** RTO estimado en 4 horas; RPO en 0 horas.

6. Declaración Ética

Declaro que todas las actividades se realizaron dentro del alcance autorizado, en entornos controlados y con fines exclusivamente académicos.

Ignacio De Paz	**04/10/2026**
Firma del estudiante	Fecha